

Volume 23

Sentinel Web Security Engine (SWSE)

Version: 1.0

Status: Draft

Vision

The Sentinel Web Security Engine is responsible for evaluating the security posture of authorized web applications, APIs, and internet-facing services.

Its objectives are to:

- Discover the attack surface.
 - Build evidence.
 - Evaluate trust.
 - Correlate findings.
 - Recommend improvements.
 - Verify remediation.
-

Engineering Principles

The Web Security Engine shall be:

- Modular
 - Explainable
 - Evidence-driven
 - Plugin-based
 - Parallelized
 - Extensible
 - Safe by default
 - Mission-aware
-

Overall Architecture

Mission

Each layer is independently testable.

Layer 1 — Discovery Layer

Purpose:

Identify all in-scope assets that should be assessed.

Supported capabilities include:

- Authorized domain discovery.
- DNS record collection.
- Public certificate collection.
- Technology identification.
- HTTP endpoint discovery.
- API endpoint identification.
- Asset relationship mapping.

The Discovery Layer updates the Knowledge Graph before deeper analysis begins.

Layer 2 — HTTP Analysis Engine

Responsibilities:

- Protocol negotiation.
- Redirect analysis.
- Response metadata.
- Security headers.
- Cookie attributes.
- Compression.
- Cache directives.
- Error handling behavior.

Each observation becomes structured evidence.

Layer 3 — TLS Assessment Engine

Responsibilities:

- Certificate validation.
- Certificate chain analysis.
- Supported protocol versions.
- Cipher suite analysis.
- Key exchange evaluation.
- Certificate expiration tracking.
- Renewal history.

Evidence is linked to:

- Domain.
 - Website.
 - Certificate object.
 - Server object.
-

Layer 4 — Technology Intelligence Engine

Instead of simply identifying technologies, Project Sentinel builds a structured technology

inventory.

Examples:

- Web server.
- Framework.
- Runtime.
- CMS.
- JavaScript libraries.
- CDN.
- Reverse proxy.
- Load balancer.

The inventory supports lifecycle management and change detection.

Layer 5 — Header Intelligence Engine

Evaluate security-relevant HTTP headers, including:

- Content Security Policy (CSP).
- HTTP Strict Transport Security (HSTS).
- X-Content-Type-Options.
- Referrer-Policy.
- Permissions-Policy.
- Cross-Origin Resource Sharing (CORS) configuration.

The engine explains the purpose of each header and its observed configuration.

Layer 6 — Cookie Analysis Engine

Assess cookie properties such as:

- Secure attribute.
- HttpOnly.
- SameSite.
- Lifetime.
- Scope.
- Prefix usage.

Recommendations include verification guidance after changes.

Layer 7 — Authentication Assessment Engine

Within authorized scope, assess authentication-related observations such as:

- Presence of MFA options.
- Session timeout behavior.
- Password policy indicators (where observable).
- Session cookie handling.
- Logout behavior.
- Account lockout configuration (where applicable).

The engine reports observed behavior without attempting unauthorized access.

Layer 8 — JavaScript Intelligence Engine

Responsibilities include:

- Inventory of referenced scripts.
- Dependency identification.
- Source map detection.
- Integrity attribute usage (Subresource Integrity).
- Deprecated library identification.
- Client-side configuration observations.

Changes are tracked over time.

Layer 9 — API Intelligence Engine

Support assessment of authorized APIs by observing:

- Endpoint structure.
- Authentication requirements.
- Versioning.
- Transport security.
- Documentation exposure.
- Response consistency.
- Rate-limiting indicators.

APIs become first-class objects in the Knowledge Graph.

Layer 10 — Visual Analysis Engine

Rather than relying solely on HTML:

The platform captures visual evidence.

Capabilities:

- Homepage snapshots.
- Login page snapshots.
- UI change detection.
- Certificate warning capture.
- Accessibility observations.

Snapshots become evidence linked to the relevant objects and missions.

Layer 11 — Trust Evaluation

The Web Security Engine contributes to:

- Website Trust.
- API Trust.
- Domain Trust.
- Certificate Trust.

Each score includes:

- Evidence.
- Confidence.

- Historical trend.
 - Recommended next actions.
-

PS-ADR-0020

Layered Web Assessment

Status: Accepted

Decision

The Web Security Engine shall consist of independent analysis engines coordinated by the Mission Orchestrator.

Rationale

A layered architecture allows incremental development, independent testing, plugin extensibility, and easier maintenance.

NEW CORE ENGINE

Website Relationship Engine

Builds relationships such as:

- Website ↔ Domain.
- Website ↔ Certificate.
- Website ↔ API.
- Website ↔ CDN.
- Website ↔ Load Balancer.
- Website ↔ Cloud Resource.

This enables impact analysis across the web environment.

NEW CORE ENGINE

Website Baseline Engine

The platform records an approved baseline for each authorized website, including:

- Expected technologies.
- Expected security headers.
- Expected certificates.
- Expected DNS configuration.
- Expected dependencies.

Future assessments compare against this baseline to highlight meaningful changes.

NEW CORE ENGINE

Accessibility Assessment Engine

Because accessibility is one of our core values, the Web Security Engine includes a dedicated assessment module that evaluates compliance with **WCAG 2.2 AA**. It checks aspects such as:

- Page titles and headings.
- Alternative text for images.
- Keyboard accessibility.
- Color contrast (where measurable).
- Form labeling.
- Language declarations.
- ARIA usage.

The goal is to help organizations improve usability and accessibility alongside security.

NEW IDEA

Website Security Passport

Each authorized website receives a continuously updated "passport" summarizing:

- Identity.
- Ownership.
- Technologies.
- Security posture.
- Trust profile.
- Accessibility status.
- Compliance mappings.
- Change history.
- Mission history.

This becomes a concise, high-level view while allowing users to drill into detailed evidence.

NEW IDEA

Executive Summary Generator

Many stakeholders are not security specialists.

The platform automatically generates audience-specific summaries:

- **Executive Summary** – business impact, priorities, trends.
- **Technical Summary** – evidence, findings, recommendations.
- **Compliance Summary** – controls, mappings, gaps.
- **Operations Summary** – mission status, verification, outstanding actions.

Each summary is derived from the same evidence base, ensuring consistency.

Looking Ahead

With the Web Security Engine defined, our next major engineering volumes will specify:

- **Endpoint Security Engine** (Windows, Linux, macOS).
- **Mobile Security Engine** (Android and iOS within supported APIs).
- **Cloud Security Engine.**
- **Identity Security Engine.**
- **Network Security Engine.**
- **Threat Intelligence Engine.**
- **Policy & Compliance Engine.**

Each will use the same object model, evidence framework, workflow engine, and trust architecture.

One proposal before we continue

As our blueprint grows, I suggest we introduce a formal "**Definition of Done**" (**DoD**) for every module. A module will only be considered complete when it has:

1. A documented architecture.
2. A Python implementation specification.
3. Automated tests.
4. Performance benchmarks.
5. Security review.
6. Accessibility review (where applicable).
7. API documentation.
8. User documentation.
9. Administrator documentation.
10. Plugin extension points.

That discipline will make Project Sentinel feel like an enterprise-grade engineering platform from the very first release, while remaining fully grounded in technologies that we can implement incrementally with Python and open-source components.

====[USER]=====

Good and continue

====[ASSISTANT]=====

Excellent. We are now entering what I think will become **Project Sentinel's flagship capability**.

If someone asks in five years:

"What makes Project Sentinel different?"

I do **not** want the answer to be:

"It has a good scanner."

I want the answer to be:

"Sentinel understands the customer's cyber environment."

That is a completely different level.

Most security tools produce findings.

Project Sentinel should produce **understanding**.

That is why the next component may become the most valuable intellectual property in the entire platform.

PROJECT SENTINEL BLUEPRINT

Volume 24